

Suman Roy

PENETRATION TESTER & APPLICATION SECURITY ENGINEER · RED TEAM · 4× CVES

hello@sumanroy.in / +91 79084 76597 / West Bengal, India (Remote) / github.com/sumanrox / linkedin.com/in/sumanrox / tryhackme.com/p/sumanrox / sumanroy.in

PROFILE

Penetration tester and application security engineer with 5+ years in security and technology, working across the offensive spectrum: web, API and cloud penetration testing (VAPT), manual and tool-assisted source code review, threat modelling, and red-team-style attack chaining. I prove vulnerabilities with reproducible PoCs and partner with engineering to fix them in the SDLC, not just report them. 4 CVEs, MSRC and Jenkins Hall of Fame, bug bounty across 46+ platforms.

SELECTED WORK & ACHIEVEMENTS

- 4 CVEs discovered & responsibly disclosed, each with a full advisory and working PoC.
 - CVE-2026-57285 · Information Disclosure in Jenkins (Medium)
 - CVE-2026-27100 · IDOR in Jenkins (Medium)
 - CVE-2025-70559 · Insecure Deserialization in pdfminer.six (High)
 - CVE-2025-70560 · Insecure Deserialization in Boltz (High)
- Microsoft Security Response Center (MSRC) & Jenkins Security Hall of Fame. Recognised by both for responsible disclosure.
- Top 1% on TryHackMe. Ranked in the top 1% of learners globally.
tryhackme.com/p/sumanrox
- Source code review at scale. Manual and tool-assisted review across 6 language ecosystems, feeding validated findings into the Checkmarx SCA platform.
- 10+ open-source security tools published. Offensive scanners and PoCs used by the community, led by RSCHunter (37★, RSC RCE), reconFavicon and Xposed.
github.com/sumanrox
- Public CVE advisories & PoCs. Vulnerability write-ups with impact, affected versions and remediation, structured as teaching material.
github.com/sumanrox/cve-research
- 46+ platforms assessed. Offensive assessments across government and private targets, with recon automated in Python.

EXPERIENCE

Penetration Tester (Freelance) Aug 2025 – Present
YesWeHack / Bugcrowd / HackerOne / Private Programs · Remote

- Penetration-test web applications and APIs across production programs, targeting authentication, authorization, access control and business-logic flaws (OAuth/OIDC, session, IDOR); discovered and disclosed 4 CVEs to date.
- Write every finding as a clean, replayable proof-of-concept a developer can reproduce from scratch, then partner with engineering to remediate and verify the fix.
- Build Python tooling to automate reconnaissance and recurring security testing across 46+ targets.

Security Researcher / Application Security Engineer Feb 2024 – Jul 2025
Loginsoft (Client: Checkmarx) · Remote

- Performed manual and tool-assisted source code review across Python, Java, PHP, Ruby, Go and JavaScript to find vulnerabilities early in the SDLC.
- Validated CVE and non-CVE findings into the Checkmarx SCA platform, with software supply-chain analysis of vulnerable package versions across ecosystems.
- Embedded security checks into developer CI/CD pipelines and gave engineers clear, actionable remediation guidance.

Senior Associate / Technical Support Specialist Nov 2019 – Dec 2021
Wipro Digital Operations & Platforms · Kolkata, India

- Resolved 1,000+ critical incidents at a 95% resolution rate with root-cause analysis on distributed-system failures.
- Mentored 18+ engineers on debugging, incident response and secure operations across enterprise-scale systems.

FOCUS AREAS

- Web / API / Android Pentest
- Source Code Review (SAST/SCA)
- Red Team & Offensive
- Threat Modelling & Secure SDLC

SKILLS

OFFENSIVE & APPSEC

- Penetration Testing
- VAPT
- Web / API / Android
- Red Teaming
- Source Code Review
- Threat Modeling
- Secure SDLC
- Auth (OAuth/OIDC/SAML)
- Supply Chain Security
- Vulnerability Research

LANGUAGES

- Python
- Go
- Rust
- Java
- JavaScript
- PHP
- Ruby
- Bash
- SQL

TOOLING

- Burp Suite
- OWASP ZAP
- Nuclei
- Semgrep
- Checkmarx
- MobSF
- Metasploit
- Nmap
- Ghidra

PLATFORMS & CLOUD

- Linux
- Docker
- Kubernetes
- AWS
- Azure
- REST
- GraphQL
- CI/CD

FRAMEWORKS

- OWASP Top 10
- OWASP ASVS
- MITRE ATT&CK
- SSDLC
- CWE / CVSS

RECOGNITION

- 4 assigned CVEs
- Microsoft Security Response Center Hall of Fame
- Jenkins Security Hall of Fame
- Top 1% on TryHackMe

CERTIFICATIONS

- CEH v12
- Cisco Cybersecurity Analyst
- Oracle Cloud Infra Associate

LANGUAGES

- English · Hindi
- Bengali (Native)